

EDA - Sistema de Gobernanza y Cumplimiento Legal

Análisis exploratorio de datos aplicado a contratos, brechas de seguridad, derechos ARCO, políticas, incidencias y riesgos.

Proyecto SQL | Modelo relacional de compliance, auditoría y gobernanza corporativa

1. Resumen ejecutivo

Este informe presenta un análisis exploratorio de datos (EDA) sobre un modelo relacional de gobernanza legal y cumplimiento. La base combina información operativa y legal para observar la trazabilidad de contratos, solicitudes ARCO, brechas de seguridad, acciones correctivas, políticas internas, evidencias, incidencias y riesgos por área responsable.

A partir de los datos cargados, se observan focos claros de atención: concentración de brechas en Seguridad de la Información, presencia de brechas no notificadas a AEPD, acciones correctivas pendientes, políticas en revisión o pendientes, incidencias abiertas y riesgos altos o críticos en varias áreas.

Indicador	Total
Áreas	10
Contratos	10
Brechas seguridad	10
Derechos ARCO	10
Revisiones contrato	10
Acciones brecha	10
Políticas	10
Incidencias	10
Riesgos	10

2. Modelo de datos analizado

La tabla AREAS funciona como dimensión central. Desde ella se relacionan las principales entidades: contratos, brechas de seguridad, derechos ARCO, políticas, incidencias y riesgos. Además, tres tablas hijas aportan trazabilidad: revisiones_contrato para contratos, acciones_brecha para brechas y evidencias_arco/evidencias_politicas para documentación de cumplimiento.

Tabla	Rol en el modelo	Relación clave
areas	Tabla maestra de áreas responsables	PK: id_area
contratos	Contratos asociados a proveedores y áreas	FK: id_area
revisiones_contrato	Histórico de revisión legal de contratos	FK: id_contrato
brechas_seguridad	Registro de brechas y severidad	FK: id_area
acciones_brecha	Acciones correctivas de cada brecha	FK: id_brecha
derechos_arco	Solicitudes RGPD/ARCO	FK: id_area
evidencias_arco	Documentación asociada a solicitudes ARCO	FK: id_solicitud
politicas	Políticas internas por área	FK: id_area
evidencias_politicas	Evidencias de cumplimiento de políticas	FK: id_politica
incidencias	Incidencias legales/compliance por área	FK: id_area
riesgos	Riesgos por categoría, nivel y estado	FK: id_area

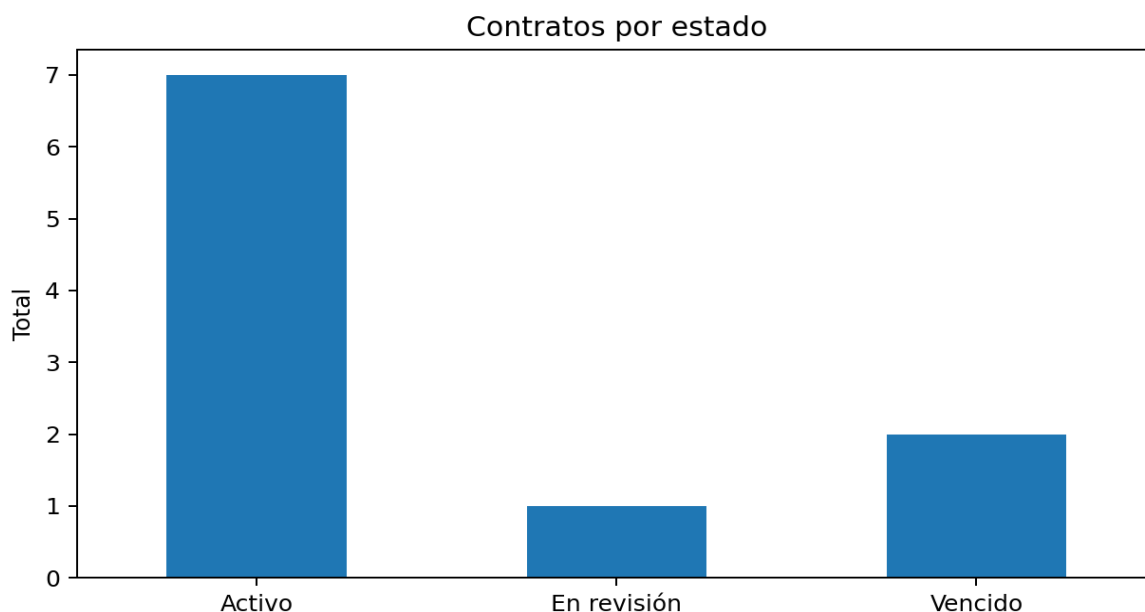
3. Calidad, cobertura y trazabilidad de datos

La carga de datos mantiene coherencia referencial: los identificadores de área, contrato, brecha y solicitud usados por las tablas hijas existen en sus tablas padre. Esto permite hacer JOINS seguros y análisis transversales sin pérdidas de información por claves inexistentes.

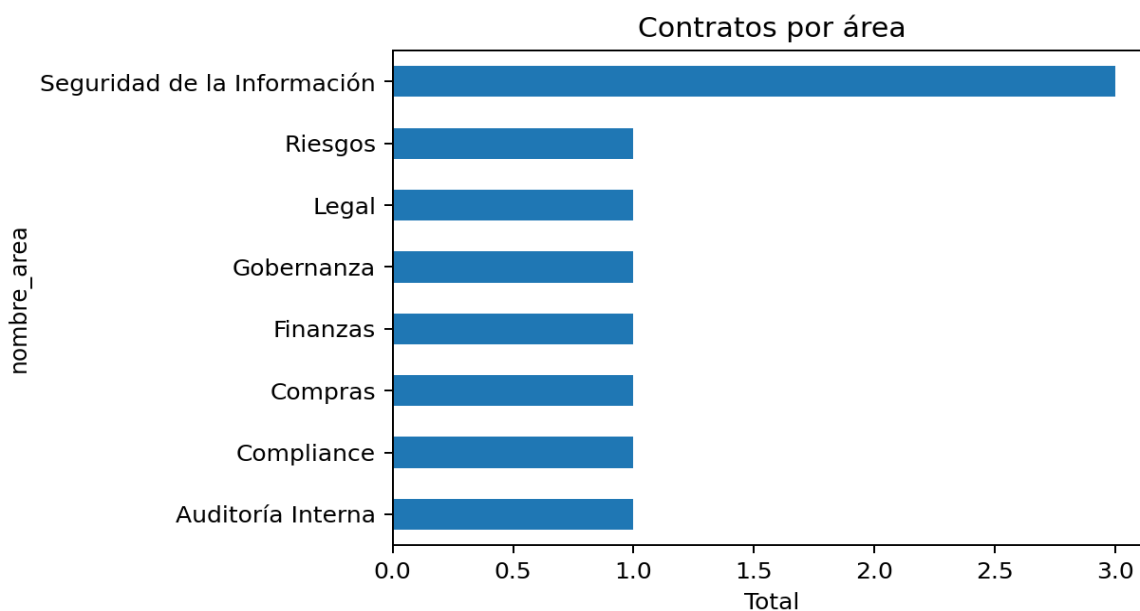
Control	Resultado	Lectura
Contratos con revisión	9 de 10	Existe al menos una revisión para 9 contratos; uno queda sin revisión.

Solicitudes ARCO con evidencia	10 de 10	Todas las solicitudes tienen al menos una evidencia.
Brechas con acción	10 de 10	Todas las brechas tienen al menos una acción correctiva.
Políticas con evidencia	10 de 10	Todas las políticas tienen registro de evidencia; no todas están entregadas.

4. Análisis de contratos

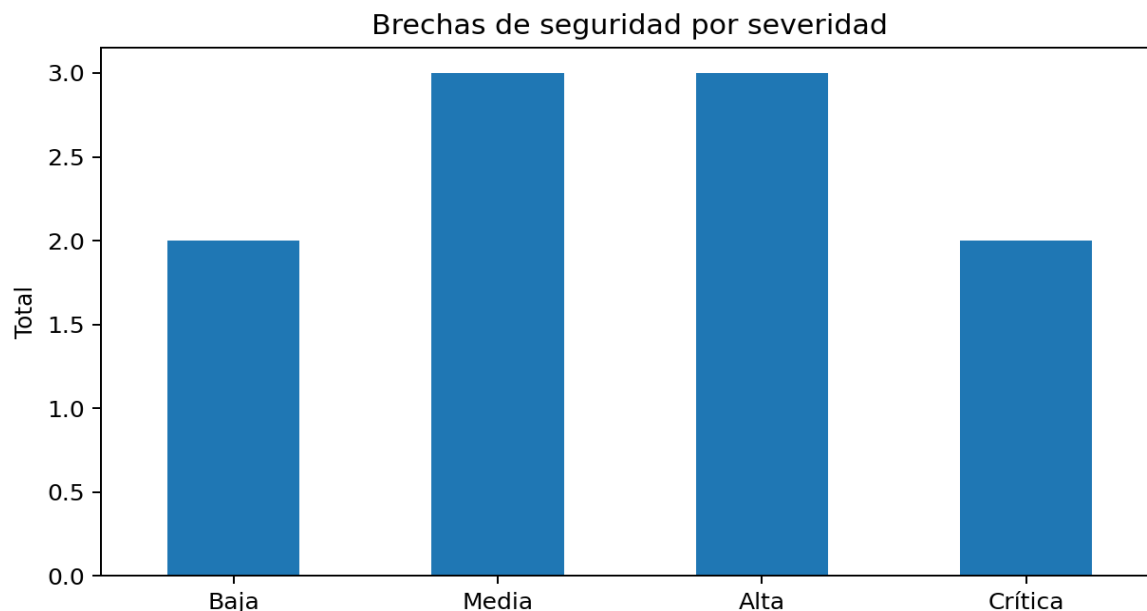


La cartera contractual está dominada por contratos activos. También existen contratos vencidos y al menos un contrato en revisión. Desde una perspectiva legal, los contratos vencidos y en revisión deben priorizarse porque pueden afectar continuidad operativa, cumplimiento contractual y exposición a riesgos con proveedores.

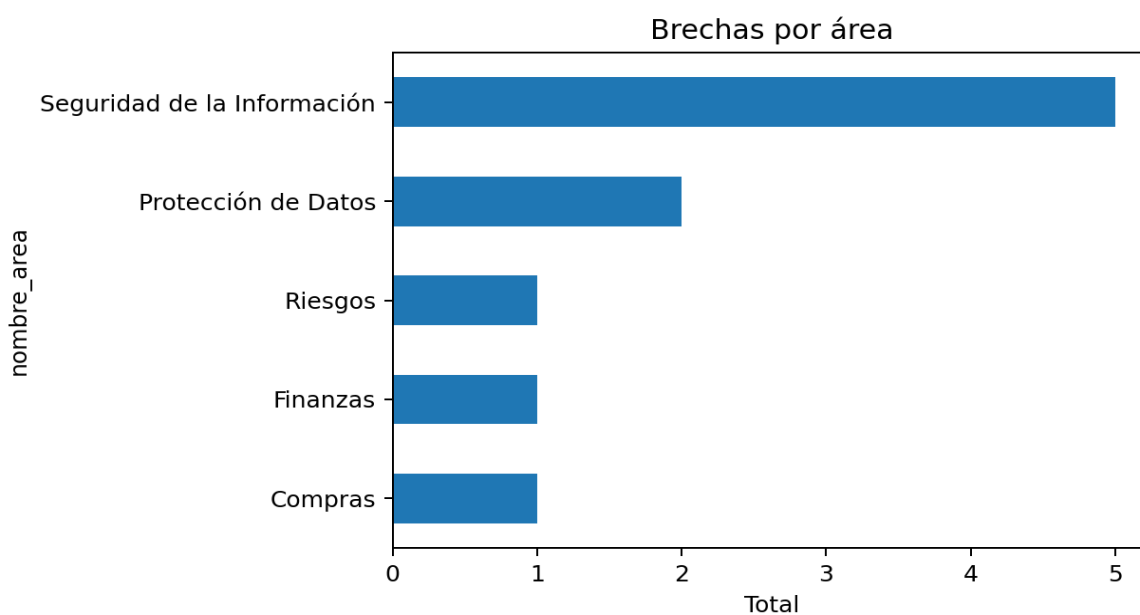


Seguridad de la Información concentra varios contratos, lo que es coherente con su peso en el modelo de brechas y acciones. Esta área debería monitorizarse de forma prioritaria por la combinación de carga contractual y exposición a incidentes de seguridad.

5. Análisis de brechas de seguridad



La distribución incluye brechas bajas, medias, altas y críticas. Las brechas altas y críticas representan el foco principal de riesgo porque pueden requerir notificación, medidas de mitigación y documentación exhaustiva para auditoría.

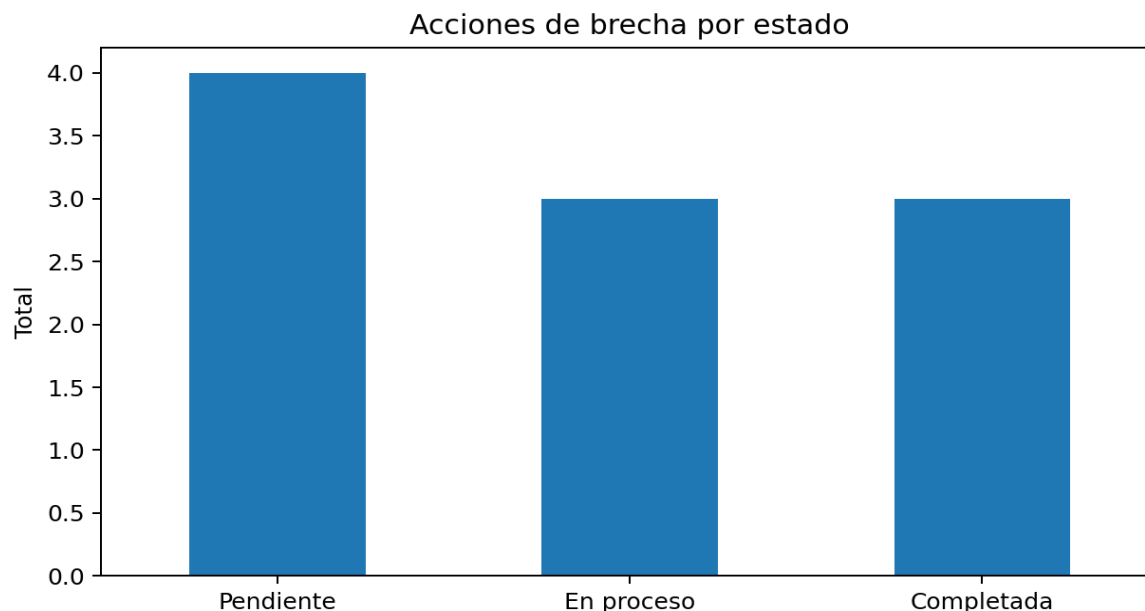


Las brechas se concentran especialmente en Seguridad de la Información y Protección de Datos. Esto es esperable en un entorno de cumplimiento RGPD, pero también exige un seguimiento estrecho de plazos, acciones correctivas y evidencias de cierre.

Estado notificación	total
No notificadas	5
Notificadas	5

Existen brechas no notificadas. No toda brecha requiere notificación automáticamente, pero las brechas de severidad alta o crítica no notificadas deben revisarse porque pueden implicar exposición regulatoria.

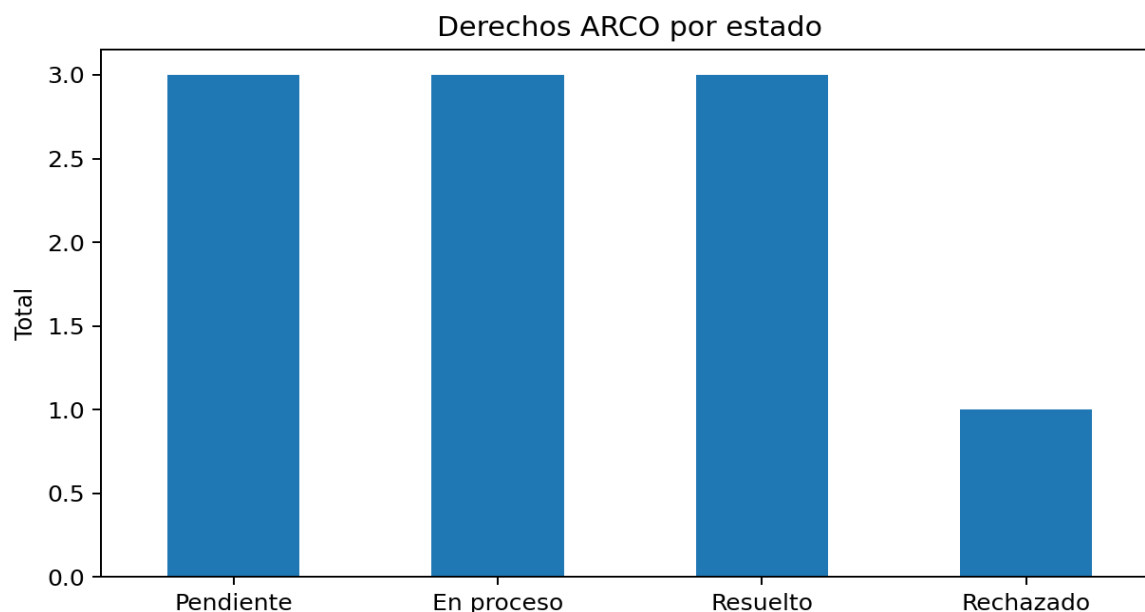
6. Acciones correctivas sobre brechas



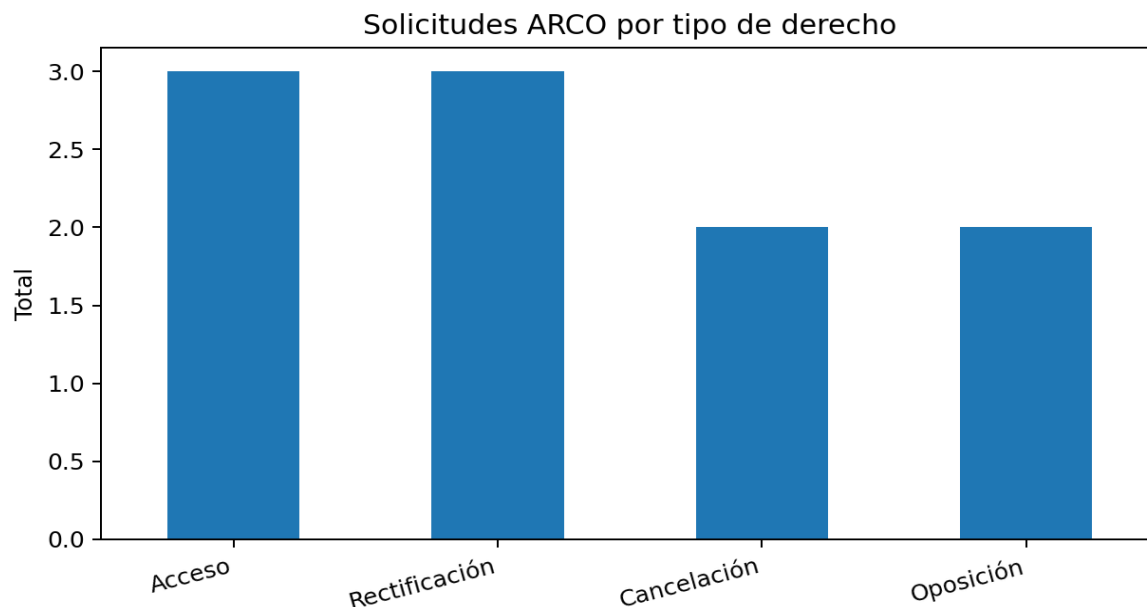
Las acciones correctivas muestran una mezcla de acciones completadas, en proceso y pendientes. El backlog pendiente es relevante porque una brecha registrada sin acción cerrada puede indicar riesgo residual no mitigado.

No se observan brechas críticas con acciones no completadas en esta muestra. Aun así, se recomienda mantener un control recurrente para detectar cambios de estado.

7. Derechos ARCO y evidencias



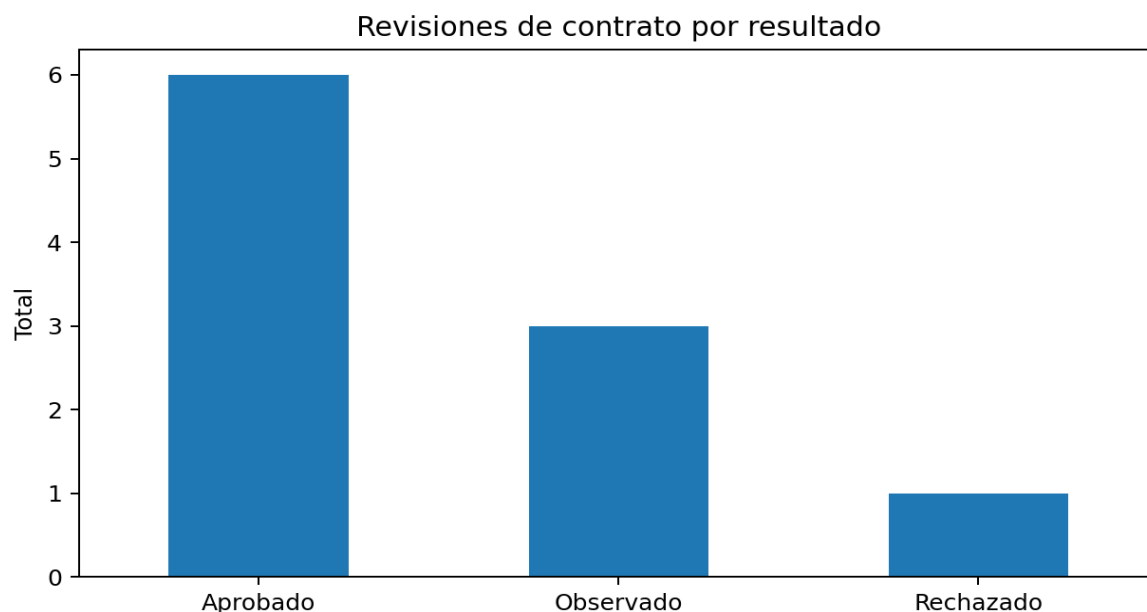
Las solicitudes ARCO se distribuyen entre resueltas, en proceso, pendientes y rechazadas. La existencia de solicitudes pendientes y en proceso permite construir indicadores de seguimiento operativo y de cumplimiento de plazos.



Los derechos de acceso y rectificación aparecen con mayor frecuencia en la muestra. Este comportamiento puede orientar la planificación de recursos del área de Protección de Datos y la automatización de respuestas o evidencias.

Todas las solicitudes ARCO tienen evidencia asociada en la muestra. Esto es positivo desde la perspectiva de trazabilidad, ya que permite justificar el tratamiento dado a cada solicitud durante una revisión o auditoría.

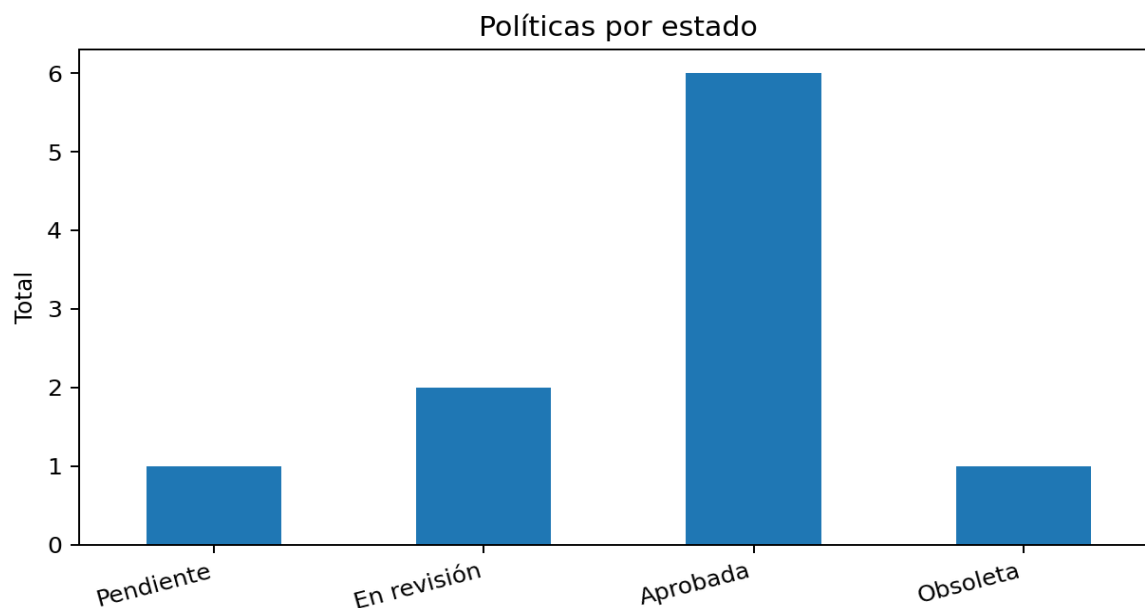
8. Revisiones legales de contratos



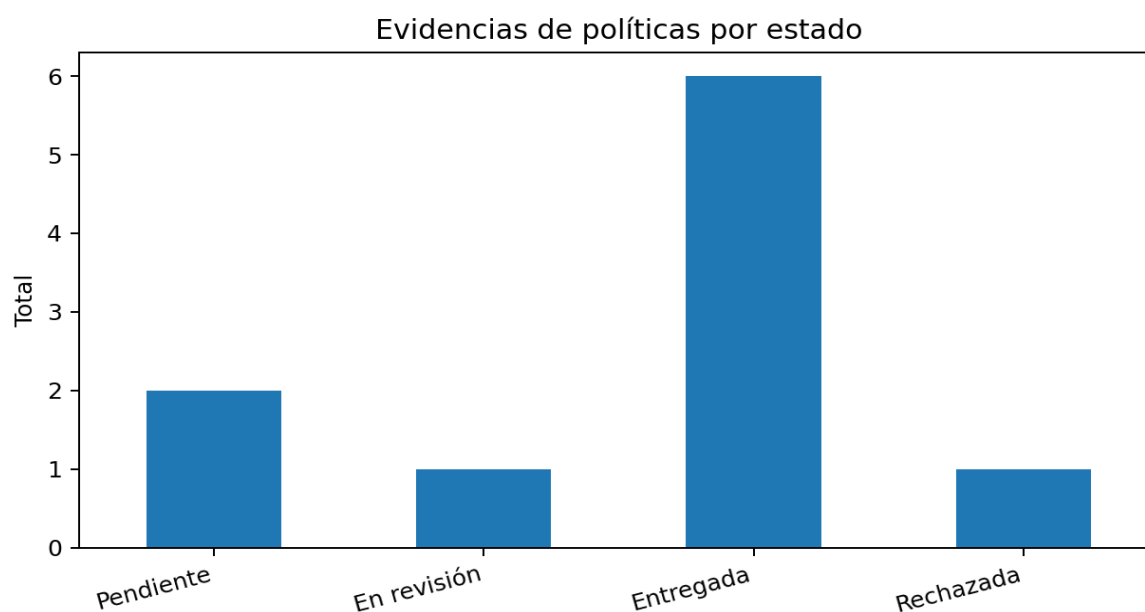
Predominan las revisiones aprobadas, pero también hay revisiones observadas y rechazadas. Las revisiones observadas requieren seguimiento porque suelen indicar cláusulas, anexos o documentación pendiente de corregir. Las rechazadas deben elevarse como riesgo contractual.

Contrato	Proveedor	Resultado
1	Accenture	Observado
3	PwC	Rechazado
5	Telefónica Tech	Observado
8	Microsoft	Observado

9. Políticas y evidencias de cumplimiento

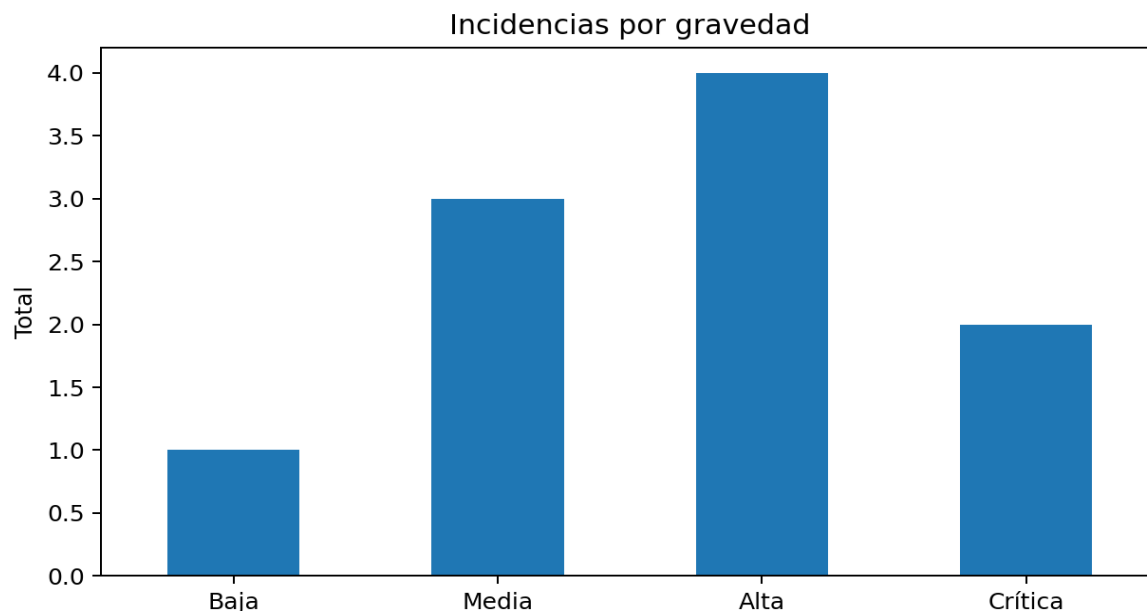


La mayoría de políticas se encuentran aprobadas, aunque también existen políticas en revisión, pendientes y obsoletas. Este punto es importante porque una política sin vigencia clara puede afectar la capacidad de demostrar cumplimiento interno.



Las evidencias de políticas muestran registros entregados, pendientes, en revisión y rechazados. La evidencia rechazada o pendiente debe revisarse porque puede convertir una política formalmente existente en un control débil o no demostrable.

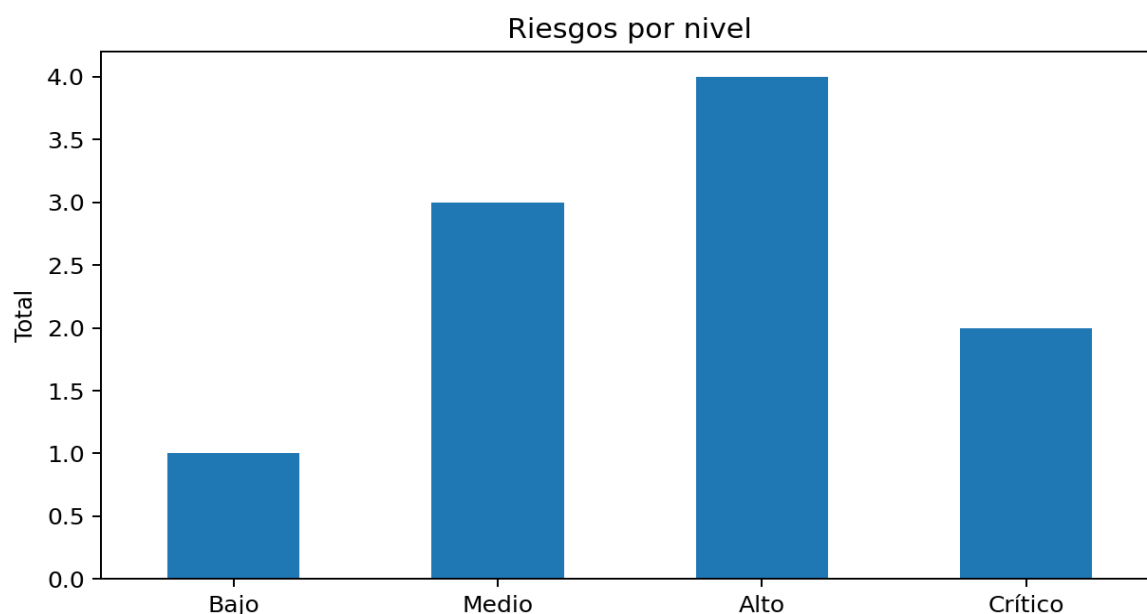
10. Incidencias legales y de compliance



Las incidencias se concentran en niveles medio, alto y crítico. Las incidencias abiertas o escaladas deberían formar parte de un seguimiento periódico, especialmente si coinciden con áreas que también tienen riesgos altos o brechas relevantes.

Estado incidencia	total
Abierta	4
Cerrada	2
En proceso	3
Escalada	1

11. Riesgos legales

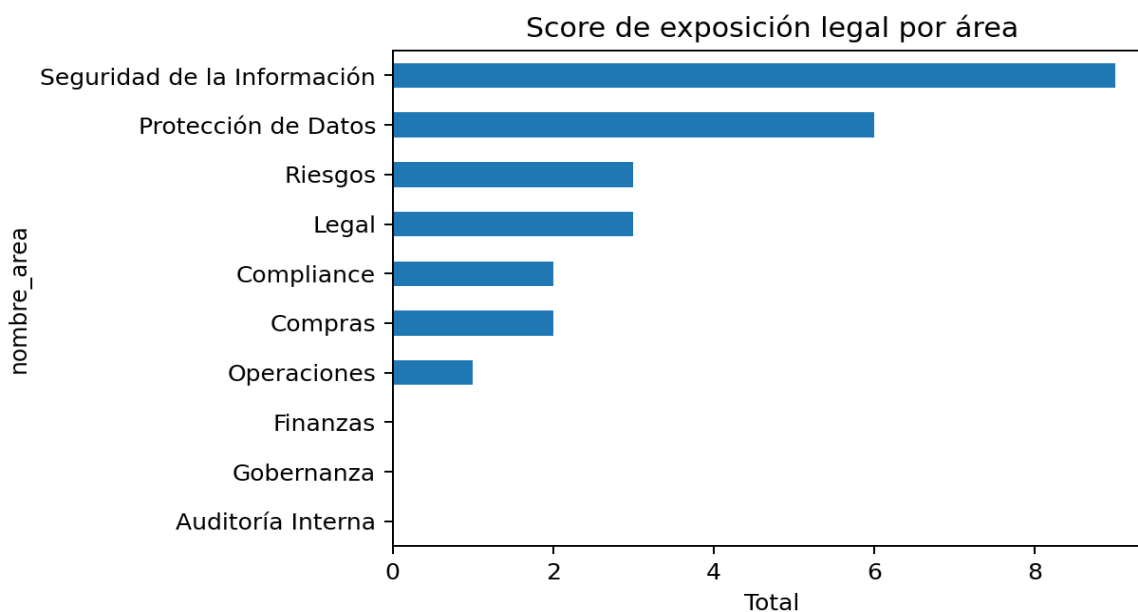


La muestra contiene riesgos bajos, medios, altos y críticos. La presencia de riesgos críticos y altos abiertos o en seguimiento indica necesidad de controles, responsables y planes de mitigación claros.

Área	Categoría	Nivel	Estado
------	-----------	-------	--------

Legal	Contractual	Alto	Abierto
Compliance	Compliance	Crítico	En seguimiento
Gobernanza	Gobernanza	Medio	Abierto
Auditoría Interna	Auditoría	Medio	Mitigado
Protección de Datos	Protección de Datos	Alto	En seguimiento
Seguridad de la Información	Ciberseguridad	Crítico	Abierto
Riesgos	Gestión de Riesgos	Alto	Abierto
Compras	Proveedores	Alto	Mitigado

12. Semáforo legal por área



El score de exposición se ha calculado de forma exploratoria ponderando brechas altas/críticas, incidencias abiertas y riesgos altos/críticos no cerrados. No es una métrica regulatoria oficial; sirve como indicador inicial para priorizar revisión y seguimiento.

Área	Contratos activos	Brechas altas/críticas	Incidencias abiertas	Riesgos altos/críticos abiertos	Score
Seguridad de la Información	2	3	1	1	9
Protección de Datos	0	2	0	1	6
Riesgos	1	0	1	1	3
Legal	1	0	1	1	3
Compliance	1	0	0	1	2
Compras	0	0	0	1	2
Operaciones	0	0	1	0	1
Auditoría Interna	1	0	0	0	0
Gobernanza	0	0	0	0	0
Finanzas	1	0	0	0	0

13. Recomendaciones estratégicas

- 1. Priorizar áreas críticas:** Revisar Seguridad de la Información, Protección de Datos y Riesgos por su concentración de brechas, riesgos altos o exposición operativa.
- 2. Formalizar KPIs de cumplimiento:** Crear indicadores de porcentaje de acciones completadas, solicitudes ARCO resueltas, políticas con evidencia entregada y contratos con revisión vigente.
- 3. Crear alertas de vencimiento:** Automatizar alertas para contratos próximos a vencer, acciones con fecha límite vencida y solicitudes ARCO pendientes.
- 4. Fortalecer trazabilidad documental:** Mantener evidencias vinculadas a políticas y solicitudes, y añadir adjuntos o rutas documentales si el modelo se lleva a producción.
- 5. Integrar con BI:** Construir un dashboard en Power BI o Tableau con filtros por área, estado, severidad, nivel de riesgo y fechas.

14. Próximos análisis recomendados

Para evolucionar este EDA se recomienda añadir importes contractuales, fechas de cierre, responsables normalizados, SLA por tipo de proceso y trazas de modificación. Con esas variables se podrían calcular tiempos medios de resolución, antigüedad de riesgos abiertos, desviaciones de SLA y coste potencial por área.